PROJECT 005

SMB Share Permission Assessment — Penetration Testing Finding Report

Assessment: Isolated Active Directory lab **Date:** October 17–18, 2026 **Status:** Tested and remediated for evaluated operations

Executive summary

An intentionally misconfigured Finance SMB share allowed a standard domain user to list restricted files, download and read a fictional budget document, and upload a new file. Broad access was granted at both the SMB share and NTFS folder layers. After removing broad share permissions, the same account received access-denied responses for directory listing, download, and upload. Subsequent NTFS hardening and file-level ACL cleanup were verified locally.

Scope and methodology

Target: DC01, corp.lab, 192.168.42.10 | **Share:** \\192.168.42.10\Finance
Testing identity: CORP\jcarter (Domain Users, IT-Staff) | **Tools:** PowerShell, icacls, smbclient
Authorization: User-owned, host-only lab with fictional data; deliberately created vulnerable configuration.

Finding 005-01 — Excessive file share permissions

Severity: High (illustrative lab judgment, no formal CVSS scoring). **Category:** Broken access control / excessive SMB and NTFS permissions.

Root cause: CORP\Domain Users was granted SMB Change and NTFS Modify access to a Finance folder intended to be administrator-restricted. Additional inherited Users permissions and a surviving user-specific file ACL required cleanup.

Verified impact: Low-privilege user listed Finance contents, downloaded budget-demo.txt and read fictional content, and uploaded smb-write-test.txt. This demonstrates unauthorized read and file creation; it does not establish existing-file overwrite, deletion, password compromise, or broader domain compromise.

Observed test outcomes

Operation	Before	After share remediation
List files	Success	NT_STATUS_ACCESS_DENIED
Download budget file	Success	NT_STATUS_ACCESS_DENIED
Upload new test file	Success	NT_STATUS_ACCESS_DENIED

Remediation and validation

Removed CORP\Domain Users from the Finance SMB share ACL and its explicit NTFS Modify permission. Confirmed the share ACL retained only BUILTIN\Administrators Full. Retested using the same standard domain account: listing, downloading, and uploading were denied. Then disabled NTFS inheritance on the folder, removed copied BUILTIN\Users entries, reviewed existing file ACLs, and removed CORP\jcarter Full Control from the uploaded test file.

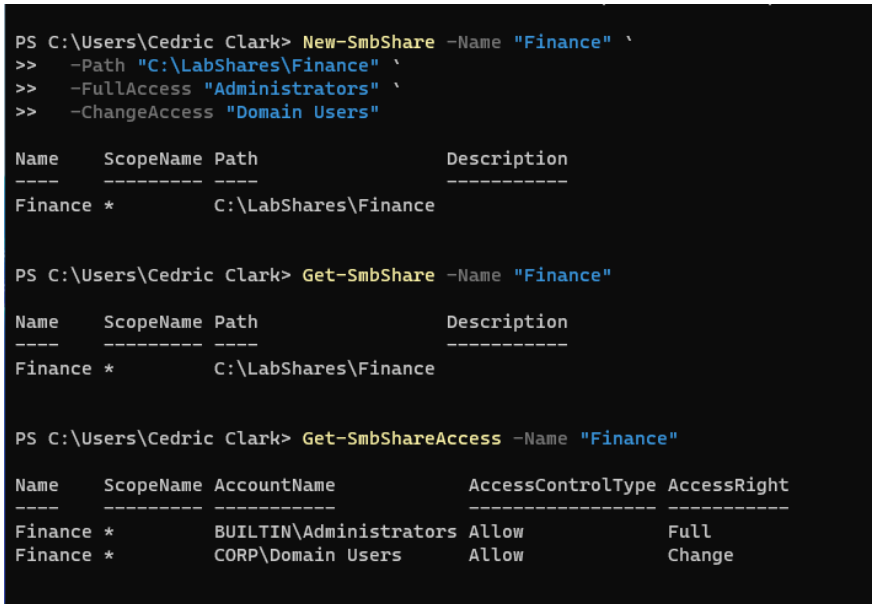
Evidence caveat: An interactive smbclient prompt appeared during one post-remediation connection attempt; this was not proof of file access. Actual operations returned access denied. Final file-level ACL cleanup was verified with icacls; no further Kali retest was captured after that final cleanup.

Recommendations

Enforce least privilege at both share and NTFS levels; grant access to dedicated authorized groups rather than all Domain Users. Review inherited and file-specific ACLs, validate permissions with a nonprivileged account, and periodically audit restricted shares.

Selected screenshot evidence

Initial SMB permissions — Domain Users Change



```
PS C:\Users\Cedric Clark> New-SmbShare -Name "Finance" `
>>   -Path "C:\LabShares\Finance" `
>>   -FullAccess "Administrators" `
>>   -ChangeAccess "Domain Users"

Name    ScopeName Path                Description
----    --------- ----                -----------
Finance *         C:\LabShares\Finance

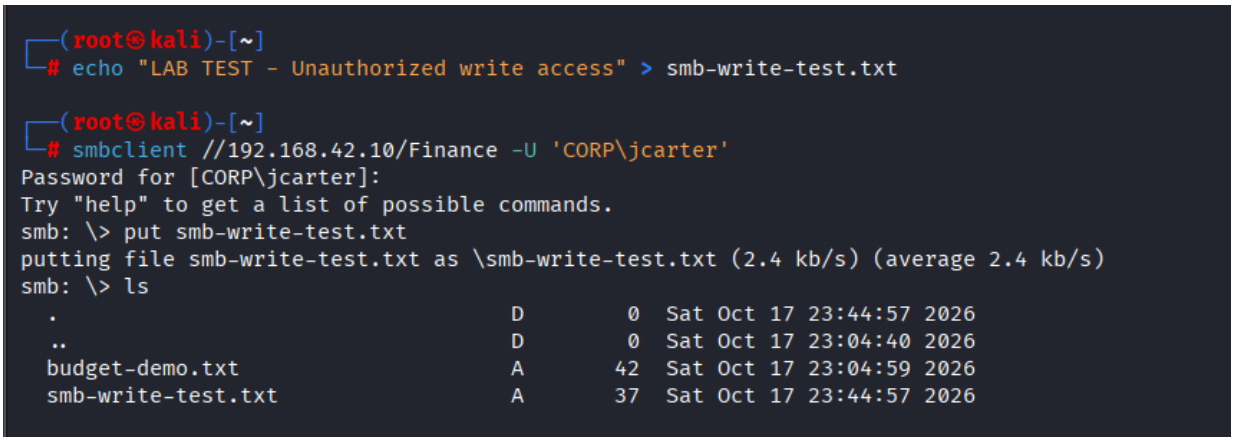

PS C:\Users\Cedric Clark> Get-SmbShare -Name "Finance"

Name    ScopeName Path                Description
----    --------- ----                -----------
Finance *         C:\LabShares\Finance


PS C:\Users\Cedric Clark> Get-SmbShareAccess -Name "Finance"

Name    ScopeName AccountName           AccessControlType AccessRight
----    --------- -----------           ----------------- -----------
Finance *         BUILTIN\Administrators Allow             Full
Finance *         CORP\Domain Users      Allow             Change
```

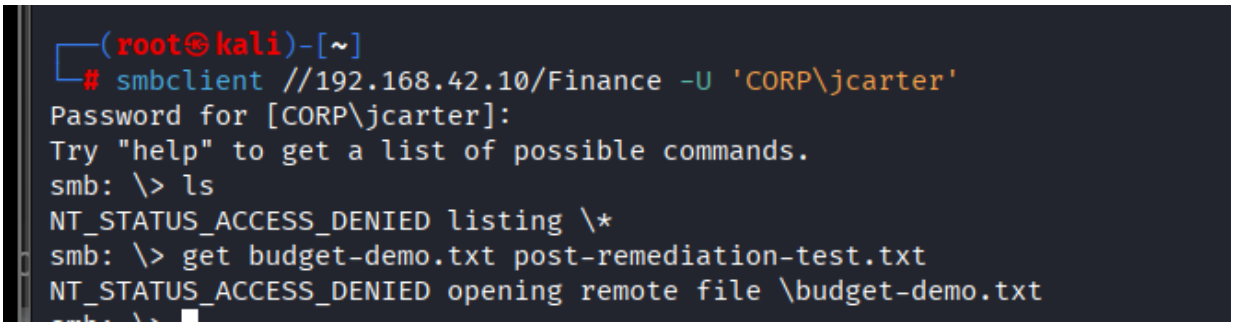
Successful upload using the low-privilege account



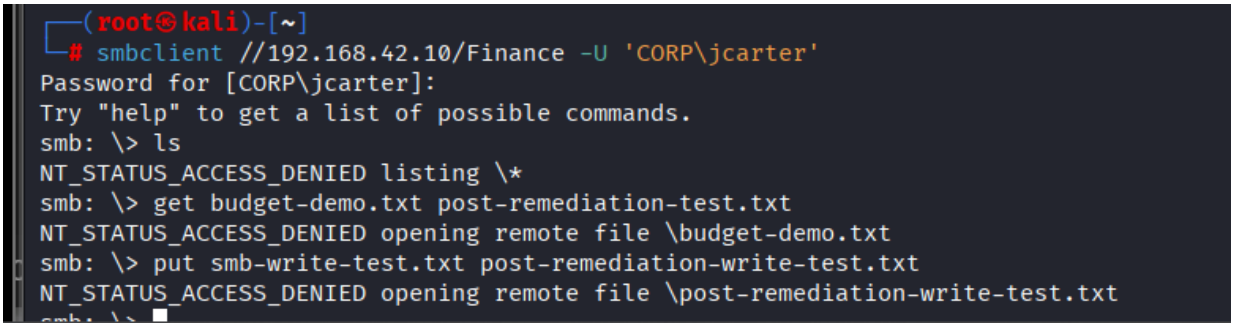
```
┌──(root㉿kali)-[~]
└─# echo "LAB TEST - Unauthorized write access" > smb-write-test.txt

┌──(root㉿kali)-[~]
└─# smbclient //192.168.42.10/Finance -U 'CORP\jcarter'
Password for [CORP\jcarter]:
Try "help" to get a list of possible commands.
smb: \> put smb-write-test.txt
putting file smb-write-test.txt as \smb-write-test.txt (2.4 kb/s) (average 2.4 kb/s)
smb: \> ls
  .                                   D        0  Sat Oct 17 23:44:57 2026
  ..                                  D        0  Sat Oct 17 23:04:40 2026
  budget-demo.txt                     A       42  Sat Oct 17 23:04:59 2026
  smb-write-test.txt                  A       37  Sat Oct 17 23:44:57 2026
```

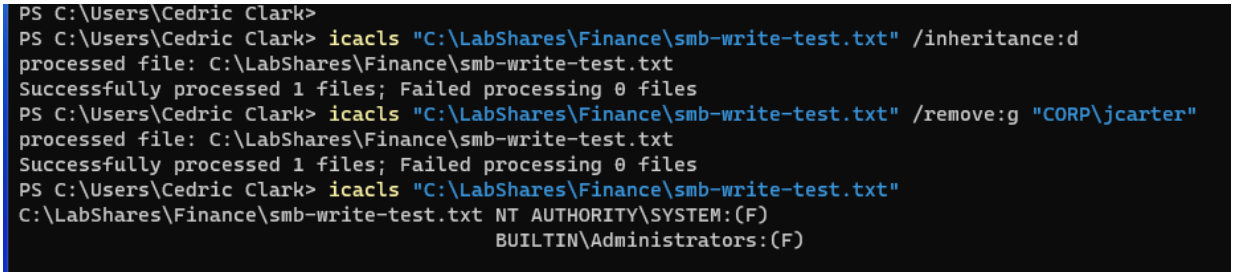
Denied file download after share-level remediation



Denied upload after share-level remediation



Final test-file ACL: SYSTEM and Administrators only



Limitations and conclusion

The tests were conducted in an intentionally vulnerable isolated lab. Results are specific to the account, share, files, and operations tested. Successful exploitation of the initial excessive permissions and access-denied retests support the finding and remediation outcome. No production environment or sensitive real-world data was involved.